

Question Paper

Exam Date & Time: 04-Jan-2026 (09:30 AM - 12:30 PM)



MANIPAL ACADEMY OF HIGHER EDUCATION

MANIPAL INSTITUTE OF TECHNOLOGY - BENGALURU
EIGHTH SEMESTER B.TECH. DEGREE MAKEUP EXAMINATIONS - JANUARY 2026

Systems and Network Security [CSE_5117H]

Marks: 50

Duration: 180 mins.

PART-A

Answer all the questions.

- 1) Early computer viruses were limited in their ability to spread and execute across systems. Today's malware, however, integrates self-replication, polymorphism, and stealth to bypass modern detection systems. Security researchers continue to struggle with building reliable signatures and predictive models against such adaptive threats. Formulate a solution exploring how the evolution of self-replicating malicious programs challenges existing detection mechanisms, which include: (5)
- A) Examine why traditional anti-virus is insufficient against evolving malware.
B) Provide a direction outlining how next-generation approaches could address this limitation.

Course Outcome: "CO1" / Cognitive Level: "Application"

- B) In a university LAN, users report that their internet traffic is intermittently redirected through an unknown gateway, and some systems receive incorrect IP and DNS settings. Network logs show that a rogue device on the same subnet is: (5)
- Responding to DHCP requests before the legitimate server,
 - Sending falsified ARP replies to hosts, and
 - Using a spoofed MAC address to impersonate the default gateway. Afterward, login credentials sent over HTTP are captured by the attacker.
- A) Analyze the sequence of attacks that led to this compromise, identifying how each protocol (ARP, DHCP, and HTTP) was exploited.
B) Perform a risk analysis strategy that could prevent or limit such attacks within the LAN.

Course Outcome: "CO2" / Cognitive Level: "Analysis"

- 2) A multinational bank deployed an anomaly-based Intrusion Detection System (IDS) to monitor network activity. (5)
- A) During a promotional campaign, a sudden surge in legitimate customer logins triggered hundreds of false intrusion alerts, causing confusion among analysts. The security audit later revealed that the IDS had not refreshed its group and resource behavior profiles for two months, and no adaptive tuning had been enabled.
- a) Analyze why the IDS misclassified legitimate traffic as malicious, linking your explanation to profile types and baseline behavior concepts.
b) Outline two technical or procedural strategies to reduce false positives while maintaining strong intrusion detection capabilities.
c) If the bank plans to upgrade its IDS to a hybrid detection model, explain how this could improve detection accuracy and what trade-offs may arise.

Course Outcome: "CO3" / Cognitive Level: "Analysis"

- B) Two system architects are designing a secure operating system for a national research laboratory. One prefers a monolithic kernel for performance, while the other argues for a microkernel citing (5)

isolation and verifiability. Management asks which design would yield a stronger Trusted Computing Base (TCB) aligned with Reference Monitor principles.

- a) Demonstrate how the two designs impact the size, verifiability, and isolation of the TCB.
- b) Based on the Reference Monitor properties tamperproof, always on, and no subject to preemption, analyze which kernel design better supports each property and why.

Course Outcome: "CO3" / Cognitive Level: "Application"

- 3) A startup developing a secure Internet of Things (IoT) operating system aims to obtain Common Criteria (CC) certification for international market trust. However, management fears that a lengthy evaluation process might delay product launch and reduce competitiveness. (5)
- A)
- A) Analyze how Protection Profiles (PP), Security Targets (ST), and Evaluation Assurance Levels (EALs) in Common Criteria influence both security confidence and time-to-market.
 - B) Recommend an assurance strategy that balances high trust with rapid deployment, explaining how the organization can make informed trade-offs between TCSEC-style assurance and business agility.

Course Outcome: "CO3" / Cognitive Level: "Analysis"

- B)
- An organization adopts a firewall policy of "allow everything not specifically denied." After deployment, it experiences malware callbacks and data exfiltration. (5)
- a) Analyze how this default-allow policy increased risk, using the concepts of rule ordering and packet filtering.
 - b) Redesign the policy as a default-deny model and justify how it enforces the least-privilege principle.
 - c) Infer how periodic rule audits and log reviews enhance long-term firewall assurance.

Course Outcome: "CO4" / Cognitive Level: "Analysis"

- 4) During a security audit, a company finds that its firewall is correctly configured but operates in isolation - without coordination with access control rules, network segmentation, or regular policy review. (5)
- A)
- a) Analyze why a firewall alone cannot ensure complete protection without supporting access controls and network-layer defenses.
 - b) Propose how layered security (defense in depth) can strengthen the firewall's effectiveness and reduce overall risk exposure.
 - c) Breakdown how periodic configuration reviews or policy audits contribute to maintaining firewall assurance over time.

Course Outcome: "CO4" / Cognitive Level: "Analysis"

- B)
- During a penetration test, security analysts discover that an attacker attempted to reuse old Kerberos authentication messages to gain unauthorized access. The system flagged this as a replay attack. (5)
- a) Demonstrate how Kerberos message formats and timestamps prevent replay attacks.
 - b) Show the importance of session keys and time synchronization between the client and KDC.
 - c) Develop one additional mechanism that can strengthen Kerberos message integrity in enterprise deployments.

Course Outcome: "CO5" / Cognitive Level: "Application"

- 5) A global open-source community uses PGP to verify contributors' code signatures. During an audit, several developers report that trusted keys appear "unverified" or "invalid," even though no breach occurred. (5)
- A)
- a) Analyze how PGP's Web of Trust establishes authenticity differently from hierarchical certificate authorities.
 - b) Infer between Owner Trust and Key Legitimacy and how confusion between them can cause trust anomalies.
 - c) Recommend one improvement that could reduce trust fragmentation or false validation in such

decentralized environments.

Course Outcome: "CO5" / Cognitive Level: "Analysis"

- B) An enterprise evaluates replacing its existing IKE-based VPN key management with SKIP to simplify operations and reduce session setup time. However, security experts warn of potential confidentiality risks. (5)
- a) Demonstrate how IKE and SKIP differ in establishing shared keys and session negotiation.
- b) Interpret why SKIP's lack of Perfect Forward Secrecy (PFS) poses a long-term confidentiality risk.
- c) Recommend whether the organization should adopt SKIP or retain IKE, justifying your answer using trade-offs between performance and security.

Course Outcome: "CO5" / Cognitive Level: "Application"

-----End-----

Event Name	Subject
058-MIT BLR-MAKEUP EXAM-2025-2026	CSE_5117H:Systems and Network Security

#	Course Outcome	Description	Marks
1	1	CO 1	5
2	2	CO 2	5
3	3	CO 3	15
4	4	CO 4	10
5	5	CO 5	15
Total			50

* **NA** - CO Not Selected

Event Name	Subject
058-MIT BLR-MAKEUP EXAM-2025-2026	CSE_5117H:Systems and Network Security

#	Level	No of Questions	Marks (%)
1	Remember	0	0(0%)
2	Understand	0	0(0%)
3	Application	4	20(40%)
4	Analysis	6	30(60%)
5	Create	0	0(0%)
6	Evaluate	0	0(0%)
Total		10	50 (100%)